

Northside Home Goods

Cyber Insurance Readiness Assessment

Prepared by: Jacob Bryer

Fictional engagement — created for portfolio purposes only. Northside Home Goods is a fictional company. No real business, customers, or systems are represented.

1. Executive Summary

Northside Home Goods has a setup that's pretty typical for a small retailer: some cloud tools, a mix of third-party providers for the core business functions, and informal security practices that have worked well enough so far. The problem is that "worked well enough so far" doesn't hold up when an underwriter starts asking specific questions about controls.

If the company applied for a cyber liability policy today, the most likely outcomes are a denial, a significantly higher premium, or exclusions on exactly the things the business would need coverage for most — ransomware and business email compromise. The gaps driving that aren't complicated. Most of them are fixable in 30 to 60 days with the right prioritization.

This report explains what's missing, why each gap matters — both for security and for insurance purposes — and what to do about it in a realistic order. The two supporting documents referenced in this assessment — an Acceptable Use Policy and an Incident Response Plan — are in the Policies/ folder.

2. Scope and Methodology

Company Profile

Northside Home Goods is a fictional small retail business selling home products through a physical storefront and a basic e-commerce site. The company has about 40 employees across sales, operations, customer service, inventory, and management. The business processes customer orders, accepts card payments, uses email for vendor communication, keeps records in cloud applications, and relies on third-party providers for payment processing, website hosting, payroll, and point-of-sale.

Assessment Scope

This assessment covers:

- Multi-factor authentication
- Email security and phishing protection
- Endpoint protection
- Backup and recovery

- Incident response planning
- Acceptable use expectations
- Administrative access controls
- Vendor and third-party risk
- Payment and customer data handling
- Security awareness training
- Business continuity considerations

Out of scope: legal review of an insurance policy, policy pricing, claim negotiation, PCI DSS certification, and technical penetration testing.

Assumptions

- Findings are based on the fictional environment and stakeholder representations described above, not on technical testing.
- No vulnerability scanning, penetration testing, or formal PCI assessment was performed as part of this scenario.
- Readiness expectations reflect common underwriting trends at the time of writing, not the requirements of any specific insurer.

Methodology

1. Review the fictional retail environment and assumptions
2. Identify systems, vendors, and processes that create cyber risk
3. Compare current practices against common cyber insurance readiness expectations
4. Document gaps that could increase the likelihood or impact of a cyber incident
5. Prioritize recommendations based on risk reduction and what's realistic for a business this size
6. Build out the supporting policy and incident response documentation

3. Key Readiness Gaps

Cyber insurers look at two things: how likely is it that a breach happens, and how bad would it be if one did? The gaps below affect both. They're organized by the risk themes most relevant to a small retail and e-commerce operation.

A. Controls That Directly Affect Underwriting Eligibility

● *Inconsistent multi-factor authentication*

MFA isn't enforced consistently across email, the e-commerce admin portal, financial tools, and remote access. This is the single most common reason a small business gets flagged, surcharged, or denied during underwriting. Insurers treat missing MFA as an unlocked front door — and they're right. Most credential-based attacks succeed because there's no second factor to stop a stolen password from being used.

● *Phishing and business email compromise risk*

Business email compromise (BEC) — where a vendor invoice gets rerouted, or a payment gets wired to an attacker's account — is one of the most financially damaging types of fraud for small businesses. Without email security controls like sender verification and link scanning, and without employees who know what a suspicious request looks like, the exposure is significant.

● *No formal security awareness training*

Staff aren't receiving regular, documented security training. There's no phishing simulation program, no recurring reminders, and no baseline to measure whether employees know what to do when something looks off. Insurers increasingly require documented training programs as a condition of coverage, not just a best practice recommendation.

● *Heavy reliance on third-party vendors*

Payment processing, e-commerce, payroll, and POS are all handled by third-party providers, but the security practices of those vendors haven't been evaluated or tracked. A breach at one of those providers is effectively a breach at Northside Home Goods from an operational and customer impact standpoint — even if the company didn't do anything wrong.

B. Business Continuity and Response Readiness

● *Backup recovery that isn't regularly tested*

Backups run on a schedule and show clean status. But clean status in a dashboard isn't the same as a working restore. Untested backups fail at a high rate, and the worst time to discover that is during a ransomware response. Insurers want documented evidence of a successful restore — not just evidence that backups are scheduled.

● *Limited incident response documentation*

There's no written playbook for what to do when something goes wrong. Without one, the response will be slower, more chaotic, and more likely to miss the insurer's notification window — which can affect whether

a claim actually gets paid. The Incident Response Plan in the Policies/ folder addresses this gap.

- ***Business continuity considerations***

The company hasn't formally defined which systems are most critical to operations — the POS, the e-commerce platform, order fulfillment — or what an acceptable recovery timeline looks like for each one. In a real outage, that means recovery decisions get made under pressure without clear priorities.

C. Governance and Documentation Gaps

- ***Weak employee acceptable use expectations***

There's no signed policy explaining what employees can and can't do with business systems. This creates legal exposure if an insider incident occurs, and insurers use the presence of a signed Acceptable Use Policy as a basic governance indicator. The AUP in the Policies/ folder addresses this gap.

- ***Limited review of privileged accounts***

Administrative access to the e-commerce platform, cloud email, payroll, and POS systems hasn't been formally reviewed to make sure only current employees have the right level of access. Privilege creep — where people accumulate access beyond what their role actually requires — is a consistent security and insurance risk, particularly for small businesses where roles change informally.

4. Remediation Roadmap

The steps below are ordered by what reduces the most risk first and what's realistic for a 40-person retail operation. Insurers also want to see evidence, not just intent — screenshots of MFA being enabled, signed policy acknowledgments, and a documented backup restore test all matter for the application.

Phase 1: Do These First (0–30 Days)

- **Turn on MFA for all 40 employees (email, remote access, financial tools, e-commerce admin).** No exceptions. This single step removes the most common entry point for a credential-based breach.
- **Sign and distribute the Acceptable Use Policy.** Get a signed acknowledgment from every employee. The signed policy itself is underwriting evidence.
- **Sign and distribute the Incident Response Plan.** Make sure the Operations Manager, IT Lead, and HR Liaison all know their roles before an incident happens, not during one.
- **Deploy managed endpoint protection on all devices** — retail registers, back-office laptops, and any device that touches business systems.

Phase 2: Build Out the Controls (31–60 Days)

- **Run a documented backup restore test.** Pick one critical system — ideally the one that would hurt most to lose — and test whether the backup actually restores it. Document the result, including how long it took, and save it as underwriting evidence.
- **Launch a security awareness training program with phishing simulations.** Monthly short training reminders and quarterly simulated phishing emails are realistic for a business this size and make a measurable difference in employee behavior.
- **Build a vendor registry for critical third-party providers.** Track who has access to customer data or business systems, confirm BAAs or data agreements are in place, and note whether each vendor has published security certifications (SOC 2, etc.).
- **Review and clean up administrative access.** Pull the list of admin accounts for key systems, remove anyone who doesn't need that level of access, and confirm that all admin accounts use MFA and unique passwords.

Disclaimer

Northside Home Goods is a fictional company created for portfolio purposes. All findings, risks, and recommendations in this folder are fictional and don't represent any real company or client. This isn't insurance, legal, or underwriting advice.